ТЕМА 1.13 · ТЕКСТ ВЫСТУПЛЕНИЯ

Понятие эталона. Отступы и классификация объектов качества

24 слайда · 15–20 минут · единый пример SYN-flood

СЛАЙД 01

Понятие эталона. Отступы и классификация объектов качества

Разберём, как программа относит объекты к разным классам и как можно объяснить её решение. Сначала разберём основные понятия: объект, признаки, модель, эталон и отступ. Потом на одном примере посмотрим, как всё это работает с сетевым трафиком. Будем отличать обычную нагрузку от SYN-flood. Возьмём одно и то же наблюдение, проверим его двумя способами и разберём, почему ответы получились разными. Затем посмотрим на остальные окна и решим, какую информацию стоит передать аналитику ИБ. Для начала договоримся о словах, которые будут встречаться дальше.

СЛАЙД 02

Объект, признаки, класс и классификация

Объектом называем то, что исследуем. Признаки описывают его через измеримые свойства. Для программы это набор значений, причём у всех объектов должен быть одинаковый набор признаков. Классом называем одну из заданных групп, к которой хотим отнести объект. Классификация как раз и состоит в выборе такой группы по признакам. Здесь важно различать сам объект, его описание и ответ, который мы ищем. Значения признаков ещё не говорят программе, какой класс выбрать. Нужно правило, которое связывает эти значения с ответом. Такое правило можно задать вручную, а можно подобрать по примерам.

СЛАЙД 03

Модель и её обучение

Правило выбора класса называется классификатором, или моделью. Оно получает признаки и возвращает ответ. Чтобы подобрать модель по примерам, собирают обучающую выборку. В ней для каждого объекта уже известен правильный класс. Этот ответ называют меткой. Во время обучения алгоритм подбирает правило по таким размеченным объектам. Потом правило применяют к другим наблюдениям. Известная метка и прогноз модели могут различаться: модель способна ошибиться. Поэтому будем отдельно показывать, какой класс задан в учебных данных и какой класс выбрала программа. Начнём с простого правила, которое опирается на образцы классов.

СЛАЙД 04

Что называют эталоном класса

Эталоном класса называем образец, который приняли для сравнения с другими объектами. У каждого класса будет свой эталон. Когда приходит новое наблюдение, мы сравниваем его с этими образцами и смотрим, на какой оно больше похоже. Пока мы определили только роль эталона. Само это понятие ещё не указывает, как именно выбрать образец. Можно использовать разные способы, и от способа зависит результат. В нашей работе выбор будет сделан по расстояниям между объектами. Поэтому прежде, чем искать эталон, нужно объяснить, что программа будет считать похожестью.

СЛАЙД 05

Как измерить похожесть

Похожесть будем измерять расстоянием. Чем меньше расстояние между описаниями двух объектов, тем они ближе по выбранному правилу. Такое правило называют метрикой. При двух признаках их значения становятся координатами точки. Евклидово расстояние измеряет прямой отрезок между точками после приведения признаков к выбранному масштабу. Масштаб здесь важен: если значения одного признака намного больше другого, они могут почти целиком определять расстояние. Поэтому заранее выбираем, как привести признаки к согласованным величинам. От этого выбора зависят и расстояния, и дальнейшие решения. В том же масштабе будем искать образцы классов.

СЛАЙД 06

Как выбрать эталон внутри класса

Для каждого класса выберем медоид. Так называют объект, у которого сумма расстояний до остальных объектов своего класса наименьшая. Посчитать его можно по шагам. Берём одного кандидата и складываем расстояния от него до остальных. Повторяем расчёт для всех кандидатов. Тот, у кого сумма меньше всего, становится нашим эталоном. Затем отдельно повторяем процедуру для другого класса. Используем только обучающую выборку. Проверочные объекты пока оставляем в стороне. При таком способе эталон всегда совпадает с существующим примером. Это особенность медоида. Когда оба образца найдены, можно описать правило классификации.

СЛАЙД 07

Как выбрать класс по эталонам

Правило ближайшего эталона устроено просто. Для нового объекта считаем расстояние до каждого образца и выбираем класс того, который оказался ближе. При точном равенстве расстояний понадобится заранее оговорённое правило выбора. Уже можно получить ответ, но хочется понять, насколько сильно один класс выигрывает у другого. Иногда один эталон значительно ближе. Иногда расстояния почти одинаковы, и небольшое изменение признаков может поменять результат сравнения. Если сохранять только название выбранного класса, эта разница потеряется. Поэтому к ответу добавим число, которое показывает преимущество правильного класса над конкурирующим. Это число называется отступом.

СЛАЙД 08

Что показывает отступ

Отступом называют разность оценок истинного класса и конкурирующего класса. Оценка показывает, насколько правило предпочитает класс. Для двух классов нам нужно сравнить всего две оценки. У ближайшего эталона оценка равна минус расстоянию: близкий образец получает большую оценку. Поэтому отступ получается как расстояние до чужого эталона минус расстояние до своего. При положительном отступе выбран правильный класс, при отрицательном чужой. Ноль означает равенство оценок. Чтобы проверить правильность по знаку, нужна истинная метка объекта. Но один образец не всегда хорошо описывает весь класс. Попробуем другой подход и обучим границу по всей выборке.

СЛАЙД 09

Как работает SVM

SVM, или машина опорных векторов, помогает обучить такое правило. В линейном варианте с двумя признаками она строит прямую, которая разделяет области выбора классов. Эта прямая называется границей решения. Когда точка пересекает её, меняется прогноз. Линейное правило вычисляет число f. По его знаку выбирается класс, а при нуле точка находится на границе. SVM обучается на всей обучающей выборке. Два эталона нужны для отдельного способа сравнения, они не заменяют эти данные. Возможных разделяющих прямых может быть много. Дальше посмотрим, что учитывает SVM, когда выбирает границу.

СЛАЙД 10

Зачем SVM нужен мягкий зазор

SVM старается оставить вокруг границы широкую полосу. Её называют зазором. Положение ближайших обучающих объектов влияет на то, какой получится эта полоса. В варианте с мягким зазором допускаются трудные случаи: отдельные точки могут находиться внутри полосы и даже на неверной стороне границы. За такие нарушения назначается штраф. Параметр C задаёт, насколько дорого они обходятся при обучении. Опорными векторами называют обучающие объекты, участвующие в определении границы. На схеме они отмечены кольцами. После обучения граница уже построена. Теперь можно измерять, насколько близко к ней находится любое новое наблюдение.

СЛАЙД 11

Геометрический отступ и запас прочности

Геометрический отступ показывает расстояние до границы со знаком. Если известна правильная метка, плюс означает верный ответ, минус ошибку. В таблицах обозначим этот отступ буквой γ. Если взять его модуль, получим расстояние r без знака. Его можно вычислить и для нового объекта, у которого ещё нет известной метки. Для линейной модели это расстояние показывает, насколько нужно изменить признаки, чтобы дойти до границы. Меньшее изменение не пересечёт её. В этом смысле говорим о запасе прочности решения. Он измерен в выбранном масштабе и не является вероятностью. Далеко от границы тоже можно ошибиться. Геометрический отступ считаем по границе, а отступ для эталонов по расстояниям до образцов. Эти значения напрямую не сравниваем. Малое расстояние до границы помогает найти пограничные случаи.

СЛАЙД 12

Что такое пограничный объект

Пограничным называем объект, который находится близко к границе. Его признаки достаточно немного изменить, чтобы модель могла выбрать другой класс. Здесь встречаются оба класса, правильные ответы и ошибки. Для отбора таких случаев после обучения задают отдельный порог расстояния. Важно различать порог перепроверки и зазор SVM. Зазор участвует в обучении и влияет на построение границы. Порог перепроверки используют уже после обучения, когда анализируют готовые ответы. Он не получается автоматически из C. Теперь мы знаем все нужные понятия. Дальше применим их к одной задаче ИБ и будем разбирать только её.

СЛАЙД 13

Пример: обычный трафик или SYN-flood

Разберём обычный трафик и SYN-flood. TCP-соединение начинается с трёх сообщений: клиент отправляет SYN, сервер отвечает SYN-ACK, клиент подтверждает ответ сообщением ACK. Так завершается рукопожатие. При SYN-flood приходит много начатых подключений, которые не завершаются. Если сервер хранит их состояние, очередь незавершённых подключений может занять ресурсы и мешать обычным клиентам. Будем относить окна трафика к нормальной работе или к SYN-flood. Большое число запросов само по себе ещё не доказывает атаку. Так может выглядеть и обычный рост нагрузки. Поэтому посмотрим одновременно на интенсивность SYN и на завершение подключений.

СЛАЙД 14

Из трафика получаем признаки

В нашем примере одно окно включает десять секунд трафика к одному IP-адресу и TCP-порту. Каждое такое окно будет отдельным объектом. Берём два признака: среднее число входящих SYN в секунду и долю попыток, у которых рукопожатие не завершилось за три секунды. В скорость входят повторные SYN. Для доли попыток повторы объединяются. Нужны оба направления обмена, а окна без SYN исключаем. Последним попыткам окна даём время завершиться, поэтому результат приходит с задержкой. В расчётах скорость делим на тысячу, проценты на сто. У нас двадцать обучающих окон, поровну нормы и атаки, и восемь проверок. Все значения придуманы для учебного разбора.

СЛАЙД 15

Выбираем два эталона трафика

По обучающим окнам нашли два медоида. Для нормы выбран N05: 600 SYN в секунду и 15 процентов незавершённых попыток. Для атаки выбран A06: 1300 SYN в секунду и 65 процентов. В ноутбуке посчитаны суммы расстояний для всех кандидатов. У этих двух объектов получились минимальные суммы внутри своих классов. Так мы получили конкретные эталоны, которые можно показать в исходных единицах. Эти числа описывают нашу учебную таблицу. Они не задают общую границу атаки для любого сервиса, поскольку обычная нагрузка у серверов разная. Проверим правило ближайшего эталона на окне T07.

СЛАЙД 16

Что эталоны скажут об окне T07

В окне T07 пришло 1200 SYN в секунду, а незавершёнными остались 16 процентов попыток. В учебной таблице это нормальный трафик. После масштабирования получаем 1,20 и 0,16. Расстояние до нормального образца около 0,600, до образца атаки около 0,500. Ближе оказалась атака, и правило дало неправильный ответ. Для известного нормального класса вычитаем своё расстояние из чужого. Получаем отступ примерно минус 0,100. Здесь хорошо видно ограничение одного образца: высокая обычная нагрузка сделала окно ближе к эталону атаки. Оставим те же измерения и проверим, что ответит SVM.

СЛАЙД 17

Теперь обучим SVM на тех же данных

Обучим линейную SVM в библиотеке scikit-learn. В ней используется SVC, готовая реализация этого метода. Берём все двадцать обучающих окон, тот же масштаб признаков и C, равное единице. Все двадцать окон участвуют в обучении, а два эталона остаются для первого способа сравнения. В коде нормальный класс обозначен минус единицей, SYN-flood плюс единицей. В ноутбуке есть отдельная ячейка обучения, а затем ячейка для получения ответа и расстояния. На выступлении достаточно показать, какие данные подаются модели и что получилось. Разбирать код построчно не требуется. Вернёмся к T07: количество SYN и доля незавершённых попыток у него остаются прежними.

СЛАЙД 18

Как SVM распознаёт то же окно T07

SVM относит T07 к нормальному трафику. По условию примера T07 относится к норме, значит, модель ответила правильно. Число f получилось примерно минус 0,249. Минус здесь выбирает норму, как мы договорились при обозначении классов. Геометрический отступ при этом положительный, около 0,102, потому что модель ответила верно. Расстояние r тоже около 0,102. Получается, у оценки f и отступа γ разные задачи: первая выбирает класс, второй позволяет проверить правильность по известной метке. Число отступа у эталонов напрямую с этим расстоянием не сравниваем. Определения разные. На одном примере SVM помогла, но это ещё не доказывает, что она всегда лучше.

СЛАЙД 19

Что получилось для всех восьми окон

Повторим расчёт для всех восьми проверочных окон. В таблице рядом стоят известный класс, прогноз SVM, геометрический отступ γ и расстояние r. У T04 и T05 отступ отрицательный. Значит, здесь ответы модели разошлись с метками. У остальных отступ положительный. Расстояние во всех строках неотрицательное, потому что это модуль γ. По одному этому столбцу нельзя определить, верно ли выбран класс. Восемь примеров специально подобраны для объяснения метода, поэтому по ним не оцениваем качество готового сетевого детектора. Чтобы легче понять положение окон, перенесём эту же таблицу на график.

СЛАЙД 20

Те же восемь окон на графике

Ту же таблицу теперь видим на рисунке. Здесь все восемь знакомых окон. По горизонтали читаем число SYN в секунду, по вертикали процент незавершённых попыток. Цвет точки показывает известный класс из учебной таблицы: бирюзовым обозначена норма, красным SYN-flood. Чёрная линия разделяет ответы SVM: выше неё модель выбирает атаку, ниже норму. Поэтому видно, где она ошиблась. T04 находится со стороны нормы, хотя это атака. T05 попало со стороны атаки, хотя это обычный трафик. T07 лежит ниже линии, на стороне нормы. Серая полоса выделяет расстояния меньше 0,10. По ней удобно увидеть окна, которые находятся совсем близко к смене ответа.

СЛАЙД 21

Какие ответы стоит перепроверить

Для перепроверки берём окна с расстоянием меньше 0,10. В этот список попадают T03, T04, T05 и T06. Здесь есть оба класса и оба типа результата. T04 показывает пропуск атаки: модель назвала вредоносное окно нормальным. T05 показывает ложную тревогу: обычное окно названо атакой. Пропуск опасен тем, что атака может остаться без внимания. Ложная тревога отнимает время аналитика, а необоснованная блокировка может помешать пользователям. В наших данных обе ошибки оказались рядом с границей. Рассчитывать, что так будут найдены все реальные ошибки, нельзя. Порог перепроверки выбран отдельно после обучения и не равен зазору SVM.

СЛАЙД 22

Что с этими результатами делать в ИБ

Передадим аналитику два отдельных сигнала. Один сообщает, что модель увидела атаку, при любом расстоянии. Другой просит проверить пограничное окно, какой бы класс ни был выбран. Учебная функция triage делает такую первичную сортировку. При 900 SYN в секунду и 40 процентах она отвечает «норма», но просит перепроверку. При 1550 SYN и 88 процентах сообщает об атаке, хотя окно вне пограничной полосы. Такие сигналы поступают в SOC, команду мониторинга и реагирования ИБ. Аналитик проверит журналы, доступность, очередь подключений, потери и обычную нагрузку. Для внедрения нужны реальные данные и валидация, то есть проверка на отдельно выделенных данных с разделением по времени.

СЛАЙД 23

Что получилось в нашем примере

На этом примере мы связали все понятия. Нашли эталоны нормы N05 и атаки A06. Сравнили T07 с ними, затем получили для того же окна ответ SVM. После этого проверили все восемь окон и увидели их на графике. По малому расстоянию выделили T03, T04, T05 и T06, включая две известные ошибки. По расстоянию видно, как близко точка к границе. Если она совсем рядом, ответ полезно перепроверить. Большое расстояние до границы само по себе не доказывает, что ответ верный.

СЛАЙД 24

Источники

Определения и методы можно проверить по этим источникам. Теория SVM есть в статье Кортеса и Вапника, материалах Stanford CS229 и документации scikit-learn. Медоиды описаны в работе Шуберта и Руссеу. RFC 4987 объясняет SYN-flood, а DeepFool рассматривает связь границы модели с изменением признаков. CICDDoS2019 указан как возможный набор данных для продолжения работы. В наших расчётах он не использован. Руководство NIST помогает разобраться в обнаружении вторжений и проверке тревог. Учебные данные, подробные расчёты и демонстрация доступны в ноутбуке Google Colab.

ИСТОЧНИКИ И МАТЕРИАЛЫ

Использованные источники

Ссылки ниже активны. Численные таблицы презентации относятся к авторскому учебному примеру.

01 Support-vector networks

C. Cortes, V. Vapnik. Machine Learning, 1995.

doi.org/10.1007/BF00994018

02 CS229: Support Vector Machines

Stanford University. Конспект лекций.

see.stanford.edu · PDF

03 Faster k-Medoids Clustering: Improving the PAM, CLARA, and CLARANS Algorithms

E. Schubert, P. J. Rousseeuw. 2018; редакция 2019.

arxiv.org/abs/1810.05691

04 RFC 4987. TCP SYN Flooding Attacks and Common Mitigations

W. Eddy. IETF, 2007.

rfc-editor.org · RFC 4987

05 Support Vector Machines — scikit-learn

Официальная документация: линейные SVM, мягкий зазор и параметр C.

scikit-learn.org · документация

06 DeepFool: A Simple and Accurate Method to Fool Deep Neural Networks

S.-M. Moosavi-Dezfooli, A. Fawzi, P. Frossard. CVPR, 2016.

cv-foundation.org · публикация PDF

07 CICDDoS2019

Canadian Institute for Cybersecurity, University of New Brunswick. Страница датасета.

unb.ca/cic · CICDDoS2019

08 NIST SP 800-94. Guide to Intrusion Detection and Prevention Systems (IDPS)

K. Scarfone, P. Mell. NIST, 2007.

csrc.nist.gov · SP 800-94